PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Gestion des risques NIS 2

01-45 Référentiel Cyber France - Mesures de gestion des risques NIS 2 — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le dirigeant exécutif est personnellement responsable de la validation de la politique de sécurité.
2. L'utilisation d'équipements personnels est prohibée pour les entités essentielles.
3. Toute compromission du cœur de confiance est considérée comme une perte totale du système d'information.

Gouvernance des SI : mesures clés

Notion	À retenir
Recensement et cartographie	Liste **exhaustive** des activités et SI associés. Exclusion possible si **aucun risque** de dégradation, divulgation ou altération. **Cartographie détaillée** requise.
Cadre de gouvernance et RH	Le **dirigeant exécutif** est responsable et nomme des **référents**. **PSSI** rédigée et validée par la direction. Sécurité : du **recrutement** (sensibilisation) au **départ** (désactivation).
Maîtrise de l'écosystème	Maintenir à jour la **cartographie des prestataires** et fournisseurs. Contrats incluant **clauses de sécurité numérique** et de **notification des incidents**.
Risques et audit (essentielles)	Gouvernance basée sur l'**analyse des risques** réévaluée **tous les trois ans**. **Programme d'audit indépendant** avec **tests d'intrusion** réguliers.

Mesures de protection des SI

Notion	À retenir
Sécurité physique et réseau	Accès **restreint et surveillé** aux locaux techniques ; SI **cloisonnés** en zones étanches ; flux filtrés par **pare-feux** (blocage par défaut).
Accès distants et malwares	Connexions externes : **chiffrement** + **authentification forte** ; équipements personnels **interdits pour les essentielles** (tolérés pour les importantes) ; antivirus sur fichiers externes.
Gestion des identités	Comptes **nominatifs** avec **droits limités** ; mots de passe par défaut **remplacés et renforcés** ; **revue annuelle** obligatoire des comptes.
Administration et durcissement	Comptes d'administration **dédiés** ; essentielles : **réseau isolé** et **postes spécifiques** ; **cœur de confiance** (annuaires) protégé au maximum ; logiciels inutiles supprimés.

Gestion des incidents et supervision

Notion	À retenir
Identification des incidents	Outils de collecte pour les **signalements d'anomalies** par les utilisateurs et analyse des **événements techniques** pour qualifier les tentatives de compromission.
Supervision continue (essentielles)	**Centre de supervision** : journaux analysés, alertes traitées sous **24 h** ; traces conservées **3 mois** au moins ; détection améliorée en continu.

Délais et conservation (entités essentielles)

24 heures
Délai de traitement des alertes par le centre de supervision

3 mois
Durée minimale de conservation des traces informatiques
pour faciliter les enquêtes

Résilience des SI : mesures clés

Notion	À retenir
Sauvegardes et continuité	Sauvegardes **régulières** avec stockage **déconnecté** (anti-rançongiciels). Plans de continuité/reprise avec **durées d'interruption tolérées**. Restauration testée **au moins une fois par an**.
Gestion de crise cyber	Procédure de gestion de crise formalisée avec **liste de contacts imprimée sur papier**. Prévoir des **moyens de communication de secours sécurisés** si le réseau principal est hors d'usage.
Entraînements réguliers	Exercices de **simulation de crise** pour valider les réflexes des **équipes dirigeantes**. Utiliser les **retours d'expérience** pour adapter les procédures après chaque incident ou entraînement.

Pièges et confusions

- ⚠ Croire qu'un système peut être exclu sans justification : les objectifs s'appliquent à toutes les entités **sauf absence de risque documentée**.
- ⚠ Appliquer les objectifs **16 à 20** aux entités importantes : par proportionnalité, ils sont réservés aux **entités essentielles**.
- ⚠ Penser que l'utilisation d'équipements personnels est autorisée pour les entités essentielles.
- ⚠ Oublier que les correctifs de sécurité doivent être appliqués sans délai sur les équipements directement exposés à internet.

Sigles et définitions

Authentification multifacteur	combine au moins deux facteurs parmi la connaissance ou la possession ou la caractéristique inhérente
Cœur de confiance	regroupe les annuaires et les ressources permettant d'en prendre le contrôle
Indicateur de compromission	trace technique manifestant une tentative d'attaque
Incident de sécurité	compromet la disponibilité ou l'authenticité ou l'intégrité des données
Réseau d'administration	dédié physiquement ou logiquement aux flux d'administration

Auto-test

1. Qui est responsable de la validation de la politique de sécurité ?
2. Quel est le délai de traitement des alertes par le centre de supervision ?
3. Quelle est la durée minimale de conservation des traces informatiques ?
4. À quelle fréquence la restauration doit-elle être testée ?
5. Tous les combien l'analyse des risques doit-elle être réévaluée ?

Réponses : **1.** Le dirigeant exécutif · **2.** 24 heures · **3.** 3 mois · **4.** Au moins une fois par an · **5.** Tous les trois ans

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.